

Universidad de la
Defensa Nacional

FADENA

Ciberseguridad aplicada

Clase 5: Unidad VII

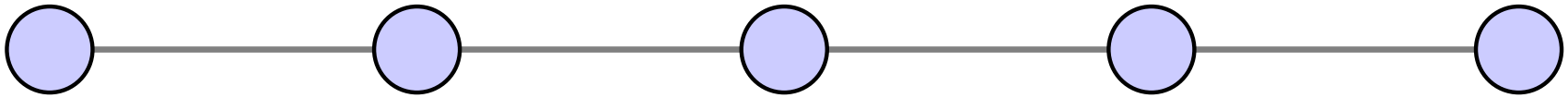
Gestión de vulnerabilidades y Segmentación de redes

4 de mayo de 2026

Ruta de la Clase 5: Unidad VII

UNIDAD VII	**UNIDAD VII**
Gestión de vulnerabilidades  Usted está aquí	Segmentación de redes

Recorrido de la Unidad VII - Gestión de vulnerabilidades y segmentación



Tema 1
Gestión de vulnerabilidades

Tema 2
Detección de vulnerabilidades

Tema 3
Priorización del riesgo

Tema 4
Superficie de ataque

Tema 5
Reducción de superficie

Tema 1 Gestión de vulnerabilidades
Tema 2 Detección de vulnerabilidades
Tema 3 Priorización del riesgo
Tema 4 Superficie de ataque
Tema 5 Reducción de superficie de ataque

Gestión de vulnerabilidades

- Proceso continuo de identificación y tratamiento de vulnerabilidades
- Parte fundamental de la gestión de riesgos
- Reduce la exposición de los sistemas

Objetivo: Disminuir la superficie de ataque de la infraestructura.

Definición de vulnerabilidad

Una vulnerabilidad es una debilidad en un sistema de información, proceso o control de seguridad que puede ser explotada por una amenaza, afectando la confidencialidad, integridad o disponibilidad de los activos.

Características

- Puede existir en software, hardware, configuraciones o procesos
- Tiene origen técnico, humano u organizacional
- Por sí sola no genera un incidente, pero habilita su explotación

Relación con el riesgo:

$$Riesgo = Probabilidad \times Impacto$$

La vulnerabilidad influye directamente en la **probabilidad de ocurrencia** de un incidente.

Referencia: NIST SP 800-30, ISO/IEC 27005

Marco de referencia

La gestión de vulnerabilidades se fundamenta en estándares internacionales:

- **NIST** – Gestión del ciclo de vulnerabilidades y evaluación de seguridad [1, 2]
- **ISO/IEC 27001** – Sistema de gestión de seguridad de la información (SGSI) [3]
- **ISO/IEC 27002** – Controles de seguridad y buenas prácticas [4]
- **OWASP** – Vulnerabilidades en aplicaciones y superficie de ataque [5]
- **MITRE CVE** – Identificación y catalogación de vulnerabilidades conocidas [6]

Enfoque común: Proceso continuo basado en riesgo y mejora constante.

Detección de vulnerabilidades

Es un proceso sistemático que combina herramientas automáticas y análisis manual para identificar debilidades en sistemas de información.

Métodos principales

- **Escaneo automatizado:** herramientas como Nessus y OpenVAS[1]
- **Monitoreo de seguridad (SIEM/XDR):** plataformas como Wazuh o QRadar para análisis de eventos y detección de comportamiento sospechoso en tiempo real[2]
- **Auditorías de seguridad:** revisión de configuraciones, políticas y cumplimiento de controles
- **Pentesting:** simulación controlada de ataques para evaluar la seguridad real del sistema
- **Bases de conocimiento:** consulta de CVE y NVD para vulnerabilidades conocidas

Idea clave: La detección efectiva integra escaneo, monitoreo continuo, análisis manual e inteligencia de vulnerabilidades.

[1] También se utilizan soluciones comerciales como Qualys o Rapid7 InsightVM, y herramientas como Burp Suite para análisis de aplicaciones web.

[2] **SIEM (Security Information and Event Management):** centraliza y correlaciona logs de múltiples sistemas. **XDR (Extended Detection and Response):** integra múltiples fuentes de seguridad para detección y respuesta unificada.

CVE (Common Vulnerabilities and Exposures / Vulnerabilidades y Exposiciones Comunes)

- Sistema de identificación único de vulnerabilidades conocidas
- Mantenido por **MITRE**
- Permite referenciar vulnerabilidades de forma estandarizada

Referencia: `https://cve.mitre.org/`

NVD (National Vulnerability Database)

- Base de datos oficial de vulnerabilidades de EE.UU.
- Administrada por **NIST**
- Enriquce los registros CVE con información adicional

Incluye:

- Puntuación CVSS
- Nivel de severidad
- Referencias técnicas y análisis

Idea clave: CVE identifica la vulnerabilidad, NVD la analiza y clasifica.

Tema 3: Clasificación y priorización

La clasificación de vulnerabilidades permite determinar el orden en el que deben ser tratadas dentro de un proceso de gestión.

Criterios de priorización

- **CVSS como referencia de severidad:** asigna una puntuación objetiva a la vulnerabilidad
- **Impacto en CIA:**
  - Confidencialidad: exposición de información sensible
  - Integridad: modificación no autorizada de datos
  - Disponibilidad: interrupción de servicios
- **Exposición del activo:** si está accesible desde redes internas o externas
- **Probabilidad de explotación:** facilidad con la que puede ser aprovechada
- **Contexto del sistema:** criticidad del servicio afectado

Priorización de vulnerabilidades

No todas las vulnerabilidades tienen el mismo nivel de criticidad ni requieren la misma urgencia de tratamiento.

Problema central

En un sistema real pueden existir cientos o miles de vulnerabilidades, por lo que es necesario establecer un orden de prioridad.

Objetivo de la priorización

- Determinar qué vulnerabilidades se corrigen primero
- Optimizar recursos de seguridad
- Reducir el riesgo operativo de forma eficiente

Idea clave: La seguridad no consiste en corregir todo, sino en gestionar el orden de tratamiento según riesgo.

CVSS como estándar de priorización

CVSS (Common Vulnerability Scoring System)
Es un estándar abierto que permite asignar una puntuación de severidad a vulnerabilidades conocidas.

¿Quién define CVSS?
El estándar es desarrollado y mantenido por el grupo **FIRST (Forum of Incident Response and Security Teams)**.

Referencia oficial: `https://www.first.org/cvss/`

¿Qué permite CVSS?

- Clasificar vulnerabilidades de baja a crítica
- Comparar vulnerabilidades de distintos sistemas
- Estandarizar la evaluación del riesgo técnico

Factores de evaluación

- Impacto en CIA (Confidencialidad, Integridad, Disponibilidad)
- Facilidad de explotación
- Nivel de acceso requerido
- Nivel de exposición del sistema

Superficie de ataque (I)

Definición
La superficie de ataque es el conjunto total de puntos de un sistema que pueden ser utilizados por un atacante para intentar acceder, comprometer o explotar recursos.

Incluye todos los vectores potenciales de exposición, tanto internos como externos.

Idea clave: Es todo aquello que está expuesto y podría ser atacado dentro de un sistema.

Superficie de ataque (II) — Ejemplos

Elementos que forman parte de la superficie de ataque

- Puertos de red abiertos y servicios en escucha
- Aplicaciones y APIs expuestas a Internet
- Servicios innecesarios habilitados en sistemas
- Credenciales débiles o privilegios excesivos
- Interfaces de administración accesibles
- Dependencias de software vulnerables

Idea clave: Cada servicio o componente expuesto incrementa la superficie de ataque.

Superficie de ataque (III) — Impacto y reducción

Relación con la seguridad

- A mayor superficie de ataque, mayor exposición a vulnerabilidades
- Incrementa la probabilidad de explotación por parte de un atacante

Reducción de la superficie de ataque

- Deshabilitar servicios innecesarios
- Control de accesos y privilegios mínimos: Principio de mínimo privilegio (IAM)
- Hardening de sistemas (eliminar servicios innecesarios)
- Segmentación de redes
- Cierre de puertos y reducción de exposición

Idea clave: Reducir la superficie de ataque disminuye directamente la probabilidad de explotación de vulnerabilidades.

Reducción superficie según capas del ciberespacio

Capa física

- Control de acceso a infraestructura (datacenters, salas técnicas)
- Protección de servidores y dispositivos de red
- Segmentación física de entornos críticos
- Eliminación de equipos no autorizados o innecesarios

Capa lógica

- Segmentación de redes (VLAN, subredes, DMZ)
- Cierre de puertos y servicios innecesarios
- Hardening de sistemas operativos
- Gestión de accesos (principio de mínimo privilegio)
- Seguridad en aplicaciones y APIs

Capa cognitiva

- Reducción de riesgo por ingeniería social
- Concientización en seguridad
- Autenticación reforzada (MFA)
- Políticas de uso seguro de la información
- Control de accesos basado en roles y responsabilidad

¿Qué es la segmentación de redes?

- División de una red en subredes más pequeñas
- Control del tráfico entre segmentos
- Aislamiento de servicios críticos

Objetivo: Limitar el movimiento lateral de un atacante.

Segmentación como control de seguridad

Es una técnica de seguridad utilizada para reducir la superficie de ataque y limitar la propagación de incidentes.

Técnicas principales

- VLANs: separación lógica de redes
- Subredes IP: organización y aislamiento de tráfico
- DMZ: aislamiento de servicios expuestos a Internet[a]
- Firewalls: control de tráfico perimetral [b] e interno [c]

Objetivo de seguridad

- Limitar el movimiento lateral de un atacante
- Reducir la exposición de sistemas críticos
- Contener incidentes dentro de segmentos controlados

[a] DMZ (Demilitarized Zone): zona intermedia entre la red interna y externa donde se ubican servicios públicos sin exponer directamente la red interna.

[b] controla el tráfico entre red externa y la red interna.

[c] controla el tráfico entre segmentos dentro de la red.

Relación con superficie de ataque

- Reduce caminos de acceso entre sistemas
- Limita propagación de ataques
- Mejora control de accesos

Idea clave: Segmentar es reducir exposición interna.

Referencias I


Technical guide to information security testing and assessment.
Technical Report NIST SP 800-115, National Institute of Standards and Technology, 2008.


Guide to enterprise patch management planning.
Technical Report NIST SP 800-40, National Institute of Standards and Technology, 2013.


Iso/iec 27001: Information security management systems, 2022.


Iso/iec 27002: Information security controls, 2022.


Owasp top 10 web application security risks.
Open Worldwide Application Security Project, 2021.

Referencias II


Common vulnerabilities and exposures (cve).
MITRE Corporation, 2026.

Muchas gracias

Retomamos las actividades en el campus virtual.
Continuamos con la segunda parte de la clase:
Segmentación de redes.

